Kali Linux Handbook: Setup, Tools & Social Engineering



By:Terry.Liu

Copyright © 2026 Terry Liu
All rights reserved.

This book is for educational and ethical cybersecurity testing purposes only.
Unauthorized access to systems is illegal.

About This Book

Want to get started with Kali Linux and social engineering?
This practical handbook covers the full workflow: installing Kali Linux, getting familiar with its built-in toolkit, and core social engineering concepts with hands-on examples.
No advanced prior knowledge required. Each chapter uses straightforward instructions to help you learn how security assessments work.
Important notice: All content is for ethical education and legally authorized security testing. Do not use any skills in this book to access accounts, devices, or systems without clear written permission. Illegal activities carry serious legal consequences.





About Me

Hi, I’m Terry or you might know me as Telly--the author of this handbook.

I am only a 13 years old studentin 2026, I like Linux and Learning cyberscurity. Also a Tech Person! Nice to meet you!

Scan the QR code to know more info about me!

Tiktoker, video editer!

My website:https://sites.google.com/view/software-sharing/home

My free Cyberscurity website:https://seculearn-academy.base44.app/

Tiktok:@telly14738

Tiktok for SecuLearn Academy:@seculearn.academy

Table of Contents

What is Kali?

Kali Linux is an open-source, Debian-based Linux distribution specifically built for advanced penetration testing, ethical hacking, digital forensics, and security auditing.

Key Use Cases

- Penetration Testing: Simulating cyberattacks to evaluate the security resilience of computer systems and networks.
- Digital Forensics: Recovering deleted data, analyzing memory dumps, and investigating security incidents.
- Vulnerability Assessment: Scanning and identifying security flaws before malicious actors can exploit them.
- Cybersecurity Education: Acting as a hands-on lab environment for students and professionals learning ethical hacking.



Kali Linux Multi-Platform Installation Guide

This comprehensive document outlines the setup steps for running Kali Linux across multiple target platforms: VirtualBox, VMware, Physical Computers (Bare Metal), and Android mobile devices.

1. VirtualBox Installation

VirtualBox provides a safe, isolated, and free environment to run Kali Linux directly on top of your current operating system.

1. **Download VirtualBox:** Visit the official VirtualBox website and download the package for your host OS (Windows/macOS/Linux). Also download the *Extension Pack*.
2. **Download Pre-Built Image:** Go to kali.org, navigate to **Virtual Machines**, and select the 64-bit VirtualBox .7z or .ova file.
3. **Extract and Import:** If using the .7z archive, extract it using 7-Zip or WinRAR. Open VirtualBox, go to *File* > *Import Appliance*, and select the extracted .ova file.
4. **Adjust Allocation:** Modify system settings to allocate at least 2 CPU cores and 4GB RAM for stable operations.
5. **Launch:** Click **Start**. Log in with default credentials.

```
Default VirtualBox Credentials:
Username: kali
Password: kali
```

2. VMware Workstation / Player Installation

VMware offers highly optimized virtualization capabilities with excellent hardware acceleration and performance scaling.

1. **Install Hypervisor:** Download and install VMware Workstation Pro (now free for personal use) or VMware Workstation Player.
2. **Get Pre-Built Image:** Go to the Kali Linux downloads site, choose **Virtual Machines**, and download the prepackaged VMware compressed folder.
3. **Extract Files:** Unzip the archive into your preferred permanent storage directory.
4. **Open VM:** Launch VMware, select **Open a Virtual Machine**, browse into the extracted folder, and pick the .vmx configuration file.
5. **Boot:** Click **Power on this virtual machine**. If prompted with an "I Moved It" or "I Copied It" dialog, choose **I Copied It** to generate new hardware IDs.

Default VMware Credentials:
Username: **kali**
Password: **kali**

3. Physical Computer Installation (Bare Metal)

Installing directly on physical hardware grants full access to network adapters, GPU processing power, and raw hardware resources.

1. **Download Installer ISO:** Visit the official website and download the complete offline **Installer Image**.
2. **Create Bootable Media:** Insert a USB flash drive (minimum 12GB). Use **Rufus** (Windows) or **BalenaEtcher** (macOS/Linux) to write the ISO image onto the drive.
3. **Configure Host Firmware:** Restart your computer, press your system's setup key (F2, F12, Del, or Esc) to enter the BIOS/UEFI. Disable **Secure Boot** and change the boot order to prioritize the USB drive.
4. **Run Installation:** Save changes and boot from the USB. Select **Graphical Install** from the boot menu.
5. **Partition Drives:** Choose your target drive. For clean installations, use "Guided - use entire disk". For dual-boot arrangements, choose manual partitioning to place Kali in unallocated free space.
6. **Finalise Setup:** Configure timezone, create your primary user credentials, accept default desktop environments (XFCE), and explicitly confirm writing the GRUB bootloader to the primary drive.

4. Android Device Installation (Kali NetHunter)

Kali NetHunter allows you to deploy penetration testing toolsets on mobile hardware utilizing targeted software frameworks.

Option A: Rootless Setup (Termux App)

Ideal for standard, non-rooted Android mobile hardware to run command-line security tools safely.

1. **Install Termux:** Download the Termux package from NetHunter App Store or Github (avoid old versions on Google Play Store).
2. **Initialize Core Packages:** Launch Termux and run updating scripts: `pkg update && pkg upgrade`
3. **Download Script:** Retrieve the NetHunter installation script by running: `wget -O install-nethunter-termux https://gitlab.com/kalilinux/nethunter/build-scripts/kali-nethunter-project/-/raw/master/nethunter-rootless/install-nethunter-termux`
4. **Set Permissions:** Grant executable access: `chmod +x install-nethunter-termux`
5. **Run Script:** Execute via `./install-nethunter-termux` and wait for the base image to install. Type `nethunter` to launch.

Option B: Rooted Framework (Full Overlay)

Provides raw kernel modifications, raw wireless injection capabilities, and full physical hardware controls.

1. **Unlock & Root:** Unlock your target device bootloader and flash **Magisk** to root the Android operating system.
2. **Custom Recovery:** Flash a custom recovery image (such as TWRP) matching your specific mobile hardware layout.
3. **Kernel Flash:** Flash a custom NetHunter-compatible kernel designed for your device to support external USB Wi-Fi cards and packet injection.
4. **Install NetHunter zip:** Download and flash the official custom NetHunter zip package through TWRP, or install via the Magisk application modules pane.

Basic Linux Commands Cheatsheet

Navigation & Directory Information

- `pwd`: **Print Working Directory.** Displays the absolute path of the folder you are currently in.
- `ls`: **List.** Shows the files and folders inside your current directory.
  - `ls -l`: Displays detailed information (permissions, size, owner).
  - `ls -a`: Shows hidden files (those starting with a dot `.`).
- `cd`: **Change Directory.** Moves you to a different folder.
  - `cd ..`: Moves up one level to the parent folder.
  - `cd ~`: Takes you straight back to your home folder.

Creating & Managing Files

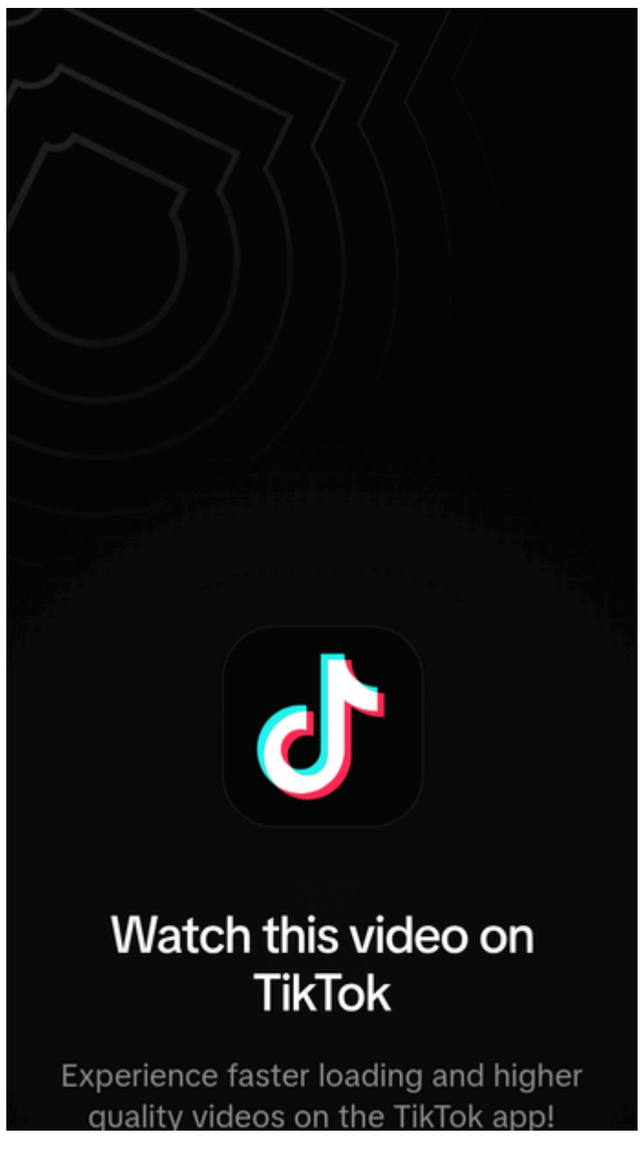
- `mkdir`: **Make Directory.** Creates a new, empty folder (e.g., `mkdir MyFolder`).
- `touch`: Creates a blank text file (e.g., `touch note.txt`).
- `cp`: **Copy.** Copies a file or folder from a source to a destination.
  - `cp file.txt /path/to/destination/`
- `mv`: **Move or Rename.** Moves a file to a new location or changes its name if kept in the same place.
  - `mv oldname.txt newname.txt`
- `rm`: **Remove.** Deletes files.
  - `rm file.txt`: Deletes a file permanently.
  - `rm -r foldername`: Deletes a directory and everything inside it recursively.

Viewing & Searching Content

- `cat`: **Concatenate.** Reads a file and prints its entire contents onto your terminal screen.
- `head` / `tail`: Displays the first (`head`) or last (`tail`) 10 lines of a file.
- `grep`: **Global Regular Expression Print.** Searches for a specific word or pattern inside text.
    - `grep "error" logfile.txt`: Finds every line containing the word "error".
- `clear`: Clears all previous text from your terminal screen to give you a clean slate.

System & Administration

- `whoami`: Prints the exact username of the profile you are currently logged into.
- `sudo`: **Superuser Do.** Runs a command with administrative/root permissions (usually prompts for your password).
- `df -h`: **Disk Free.** Shows your hard drive's available space in a human-readable format (GB, MB).
- `free -h`: Displays the amount of free and used RAM memory available on the machine.



Kali Linux: Most Used Tools & Guide

Kali Linux includes hundreds of security and penetration testing utilities. Below are the most frequently used tools and basic instructions on how to use them.

1. Nmap (Network Mapper)

- **What it does:** Scans networks to discover live hosts, open ports, running services, and operating systems.
- **How to use it:**

Basic port scan:

```
nmap <target-ip>
```

Detect service versions and operating systems:

```
nmap -sV -O <target-ip>
```

2. Metasploit Framework

- **What it does:** The industry-standard exploitation framework containing a vast database of known exploits and payloads.
- **How to use it:**

Launch the interactive console:

```
msfconsole
```

Search for an exploit:

```
search <keyword>
```

Use an exploit and set options:

```
use
exploit/path/to/exploit set
RHOSTS <target-ip>
exploit
```

6. John the Ripper / Hashcat

- **What it does:** Password and hash cracking tools used to test password strength offline against dictionary or rule-based attacks.
- **How to use it (John the Ripper):**

```
john --wordlist=/usr/share/wordlists/rockyou.txt <hash-file>
```

How to use it (Hashcat):

```
hashcat -m 0 -a 0 <hash-file> /usr/share/wordlists/rockyou.txt
```

7. Hydra

- **What it does:** A fast online brute-force login cracker that tests username and password combinations against network services (SSH, FTP, HTTP, etc.).
- **How to use it:**

```
hydra -l <username> -P <password-list.txt> <target-ip> ssh
```

8. Nikto

- **What it does:** A web server scanner that tests for dangerous files, outdated server software, and general misconfigurations.
- **How to use it:**

```
nikto -h http://<target-ip>
```

9. Netcat

- **What it does:** Often called the "Swiss Army knife" of networking; reads and writes data across network connections, checks ports, or spawns reverse/bind shells.
- **How to use it:**

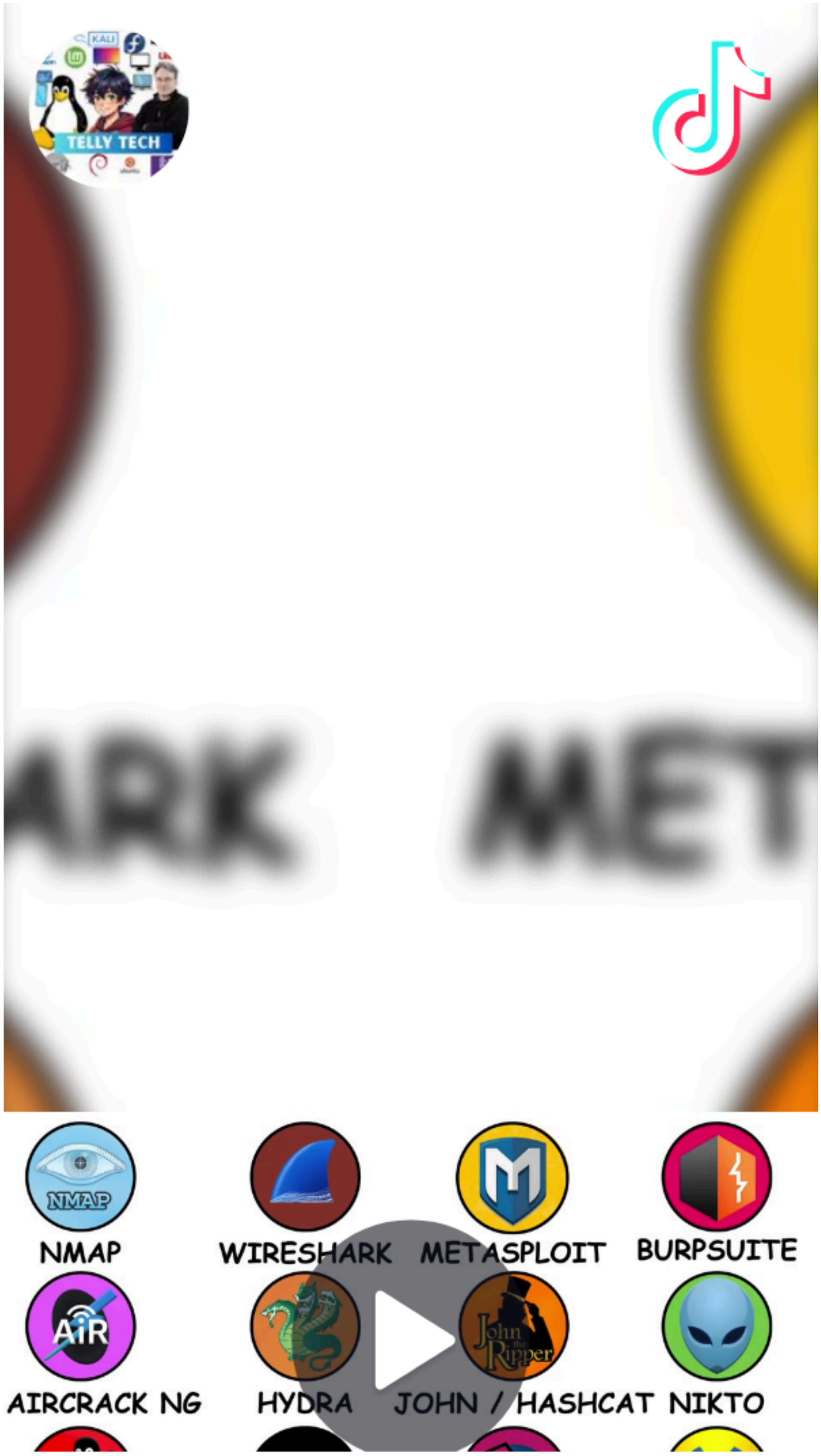
Listen for an incoming connection on a specific port (e.g., for a reverse shell):

```
nc -lvnp 4444
```

10. SQLmap

- **What it does:** Automates the detection and exploitation of SQL injection (SQLi) flaws in web applications.
- **How to use it:**

```
sqlmap -u "http://target.com/page.php?id=1" --dbs
```



Cybersecurity Analysis: Phishing Tactics & Frameworks

This document provides an educational overview of digital deception techniques, focusing on how strategic manipulation, delivery mechanisms, and automation frameworks intersect during simulated security assessments.

Core Definitions

- **Social Engineering:** The psychological strategy. It is the art of manipulating human behavior—using tactics like fear, authority, or curiosity—to trick someone into breaking normal security protocols.
- **Phishing Mailer:** The delivery mechanism. It is a software tool or script that automates sending thousands of deceptive emails or SMS messages disguised as legitimate alerts (e.g., a fake bank notification or password reset).
- **Zphisher:** The credential trap. It is an automated, open-source phishing framework used in Linux environments (like Kali Linux) that instantly spins up realistic copies of popular login pages to capture credentials.

The Simulated Attack Workflow

In authorized cybersecurity testing, professionals combine these components to evaluate organizational resilience:

1. Intelligence Gathering & Social Engineering Design

- **The Goal:** Build a believable pretext.
- **The Action:** Testers research public corporate details to determine active software. They choose a psychological trigger, such as an urgent notice stating *"Your corporate password expires in 2 hours,"* to force quick compliance.

2. Crafting the Trap (Using Zphisher)

- **The Goal:** Host a fake website to capture credentials.
- **The Action:** The framework is deployed via a terminal interface to select a targeted template.
- **Port Forwarding:** The local instance integrates with tunneling tools (e.g., Ngrok or Cloudflared) to generate a temporary public URL. When a target enters their data, the harvested credentials appear directly in the controller's console.

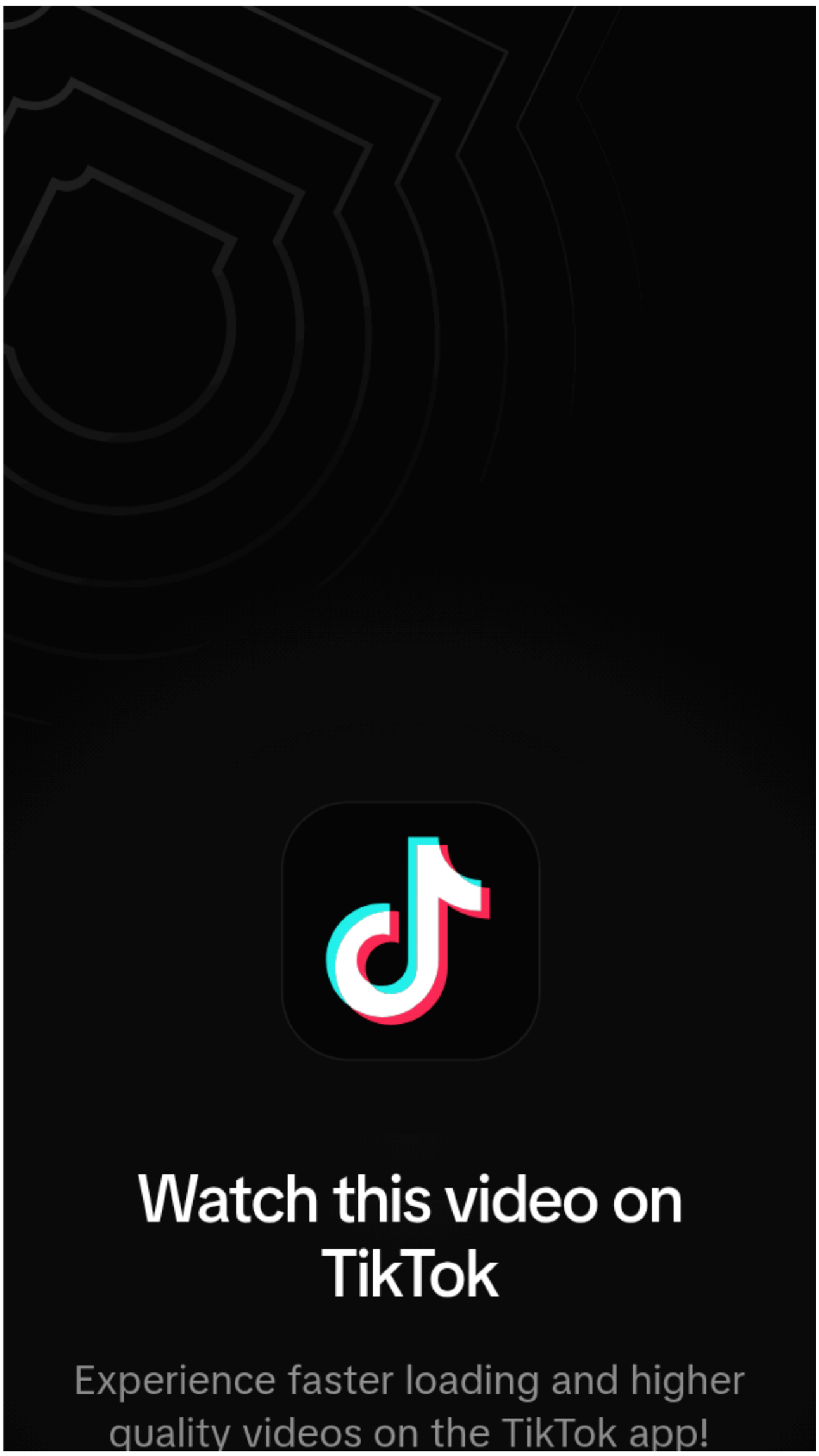
3. Mass Delivery (Using a Phishing Mailer)

- **The Goal:** Distribute the malicious payload link.
- **The Action:** The public URL generated by Zphisher is embedded into the pre-designed email template. A mailer utilizes SMTP (Simple Mail Transfer Protocol) configurations to broadcast the message across the target pool.

Defensive Strategies & Mitigation

Breaking any individual link in this execution chain neutralizes the threat:

- **Secure Email Gateways:** Enterprise filters scan incoming mail for malicious links, known phishing mailer signatures, and domain spoofing to block delivery.
- **Domain Reputation Blocks:** Corporate firewalls automatically drop outbound traffic heading toward newly registered domains or known public tunneling URLs (like .ngrok-free.app or .trycloudflare.com).
- **Phishing-Resistant MFA:** Cryptographic authentication standards (such as FIDO2 and YubiKeys) map tokens directly to the true root domain, ensuring intercepted credentials alone cannot grant access to accounts.





features

- Latest and updated login pages.
- Beginners friendly
- Multiple tunneling options
- Localhost
- Cloudflared
- LocalXpose
- Mask URL support
- Docker support

Installation

Just, Clone this repository -

```
git clone --depth=1 https://github.com/htr-tech/zphisher.git
```

Now go to cloned directory and run zphisher.sh -

```
$ cd zphisher
$ bash zphisher.sh
```

On first launch, It'll install the dependencies and that's it. Zphisher is installed.

Installation (Termux)

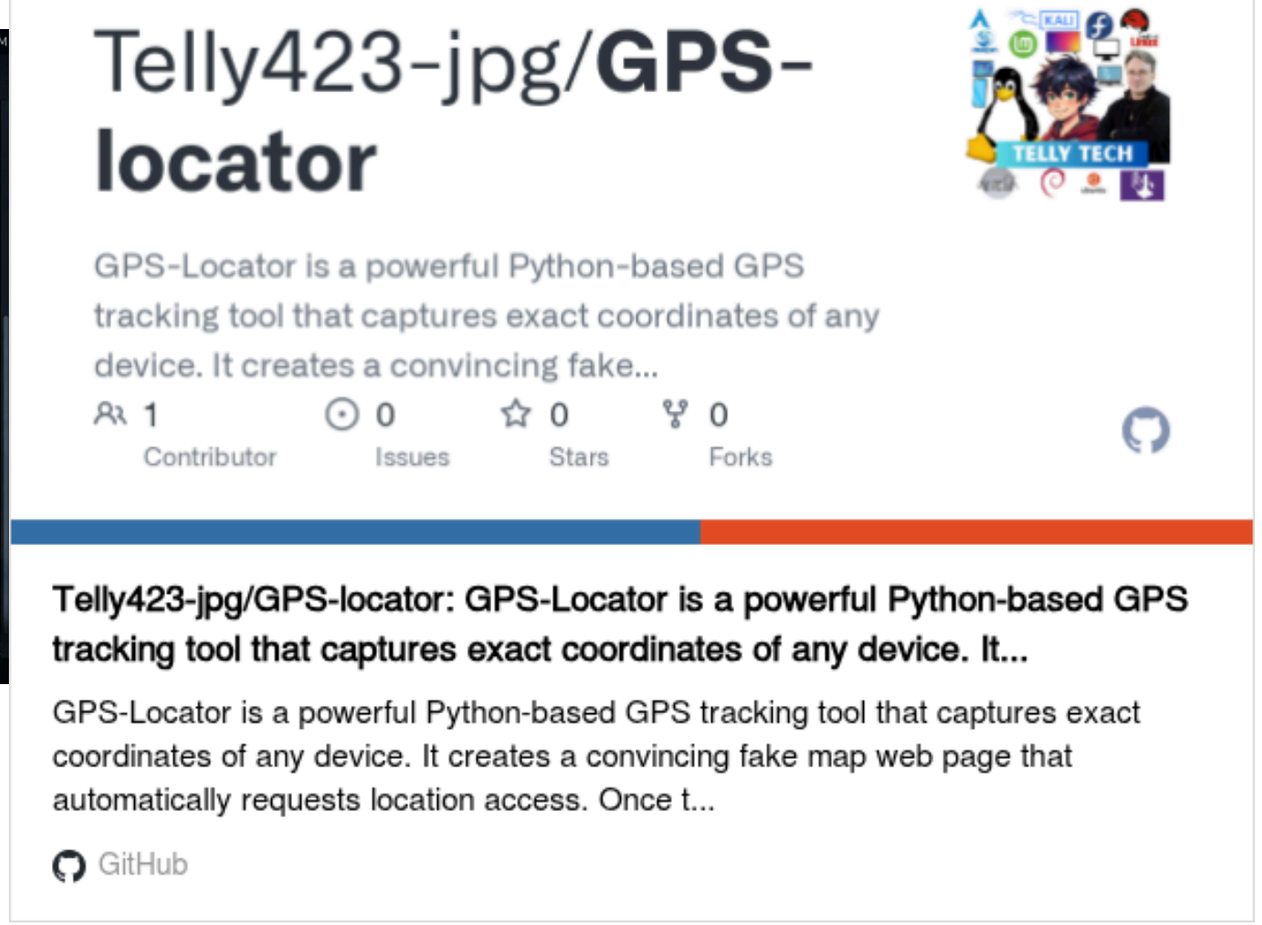
You can easily install zphisher in Termux by using tur-repo

```
$ pkg install tur-repo
$ pkg install zphisher
$ zphisher
```

GPS-Locator

GPS-Locator is a powerful Python-based GPS tracking tool that captures exact coordinates of any device. It creates a convincing fake map web page that automatically requests location access. Once the target grants permission, their precise location is captured and displayed on a real-time map.



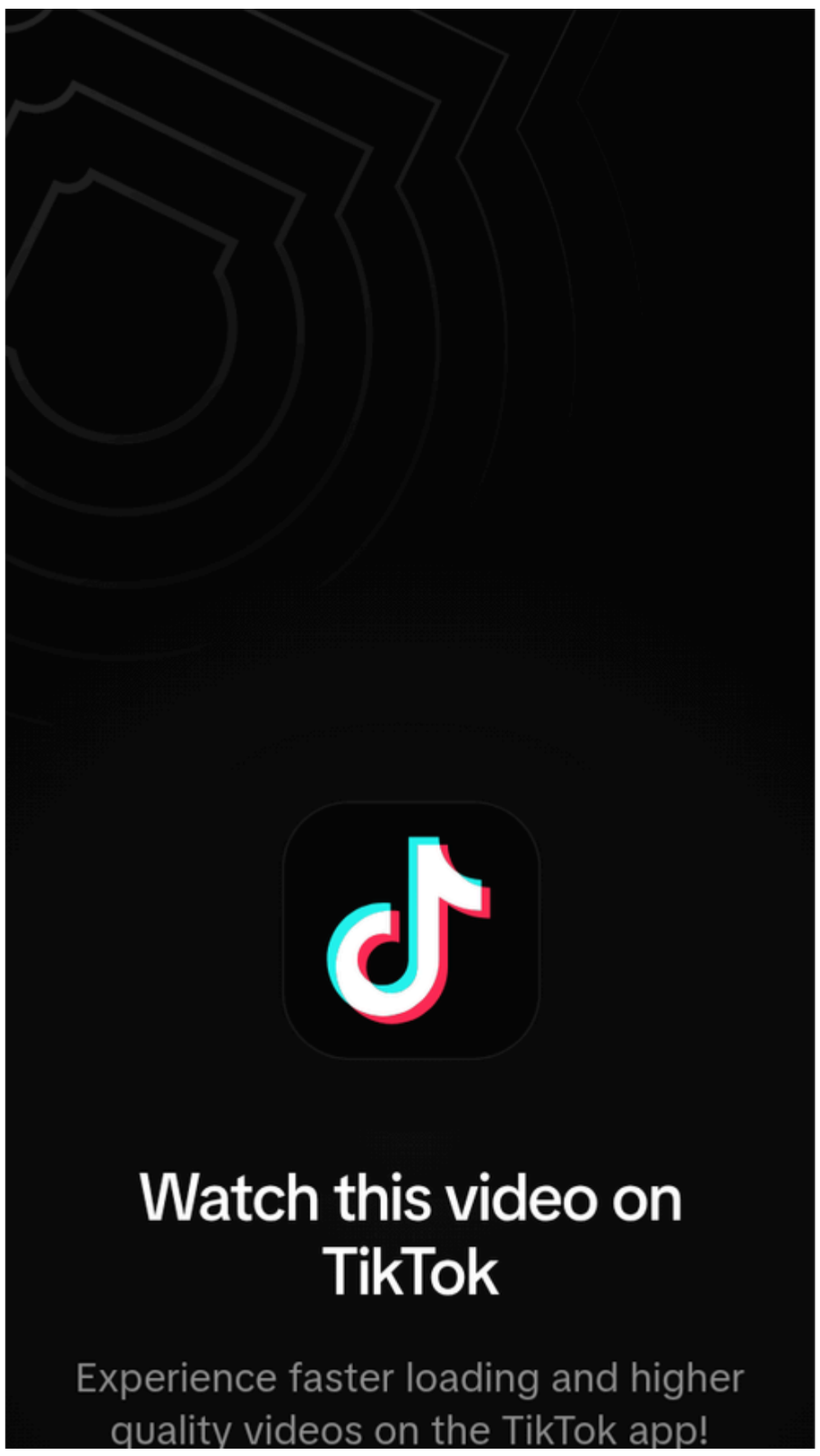


This project is a modified version based on the original HDN-Locator by HasnainDarkNet, following the MIT License. google maps locator.py is the modified and ready-to-run script, you just need to open locator.py, replace the original html with the other local html files path in this repository, save and run it.

how to download(linux)

1. git clone https://github.com/Telly423-jpg/GPS-locator.git
2. cd GPS-locator
3. ls
4. python3 locator.py

✨ Features
🎯 Exact GPS Coordinates - Captures latitude, longitude & accuracy
🗺️ Real-time Map - Built-in Leaflet map visualization
🛡️ Anti-Spoofing - Detects fake/mock GPS apps
🔗 Public Link - Cloudflare tunnel for external access
📱 Cross-Platform - Works on Windows, Linux & macOS
🎬 Fake web Page - Convincing UI design
💾 Auto Save - All data saved in JSON format



What is a DDoS Attack?

A Distributable Denied-of-Service (DDOS) attack server that cuts off targets or surrounding infrastructure in a flood of Internet traffic
DDoS attacks achieve effectiveness using multiple compromised computer systems as a source of attack traffic. Search engines may include computers and other network resources such as IoT devices. From a higher level, the DDOS attack is like an unexpected traffic jam stuck on a highway, preventing regular traffic from reaching its destination.



For Termux

To use the DRipper type the following commands in Termux:
pkg install git -y
pkg install python -y
pkg install python3 -y
git clone https://github.com/palahsu/DDoS-Ripper.git
cd DDoS-Ripper $ ls
$ python3 DRipper.py
USGAE
python3 DRipper.py -s [ip Address] -t 135
example: python3 DRipper.py -s 0.00.00.00 -t 135

For Debian-based GNU/Linux distributions

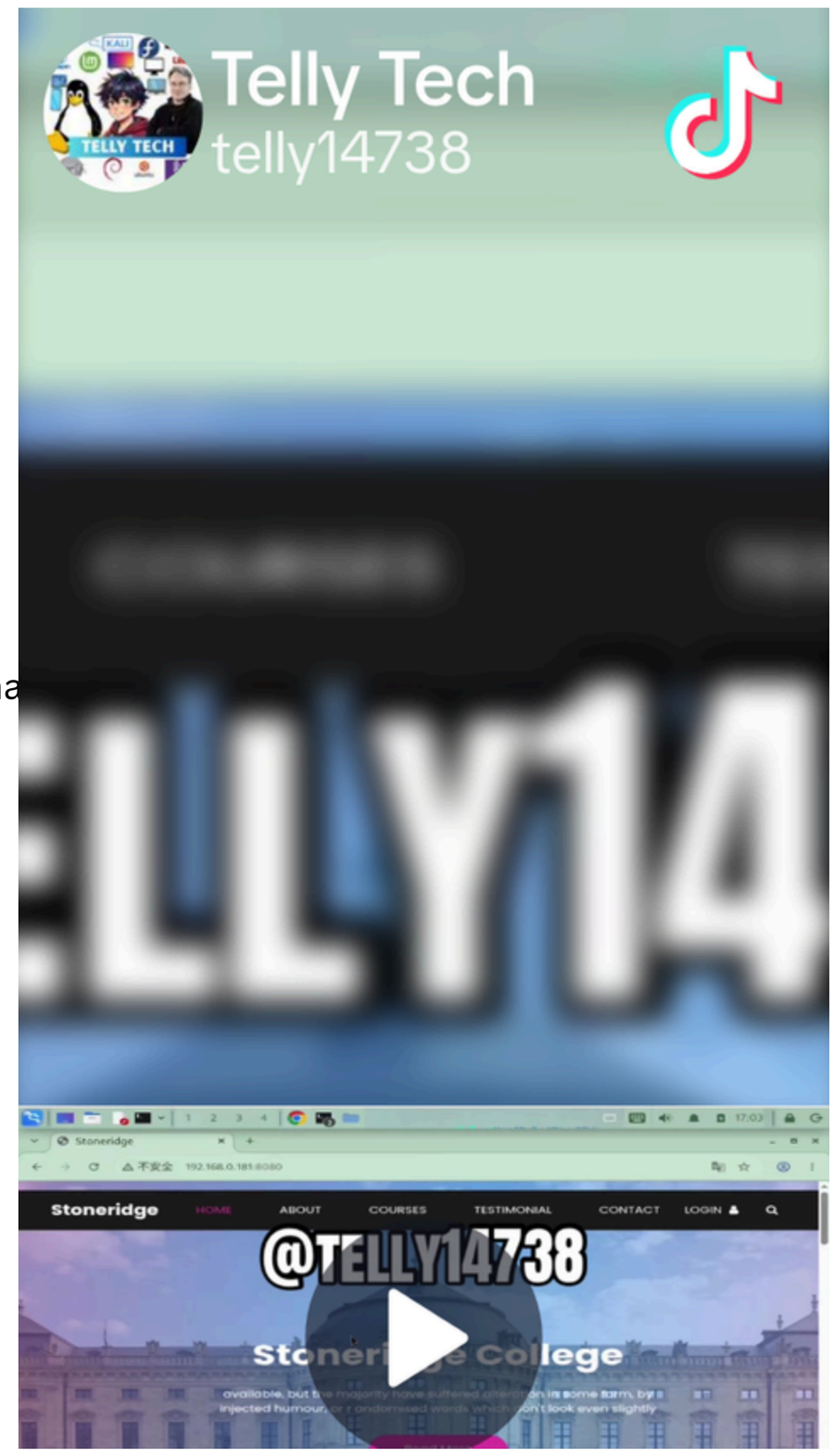
To use the application, type in the following commands in GNU/Linux termina
sudo apt install git git clone https://github.com/palahsu/DDoS-Ripper.git
cd DDoS-Ripper
$ ls
$ python3 DRipper.py OR python2 DRipper.py

For Windows

git clone https://github.com/palahsu/DDoS-Ripper
cd DDoS-Ripper ls
python3 DRipper.py OR python DRipper.py
python3 DRipper.py -s [ip Address] -t 135
example: python3 DRipper.py -s 0.00.00.00 -t 135

For MacOS

Install Brew and Install dependencies (python 3)



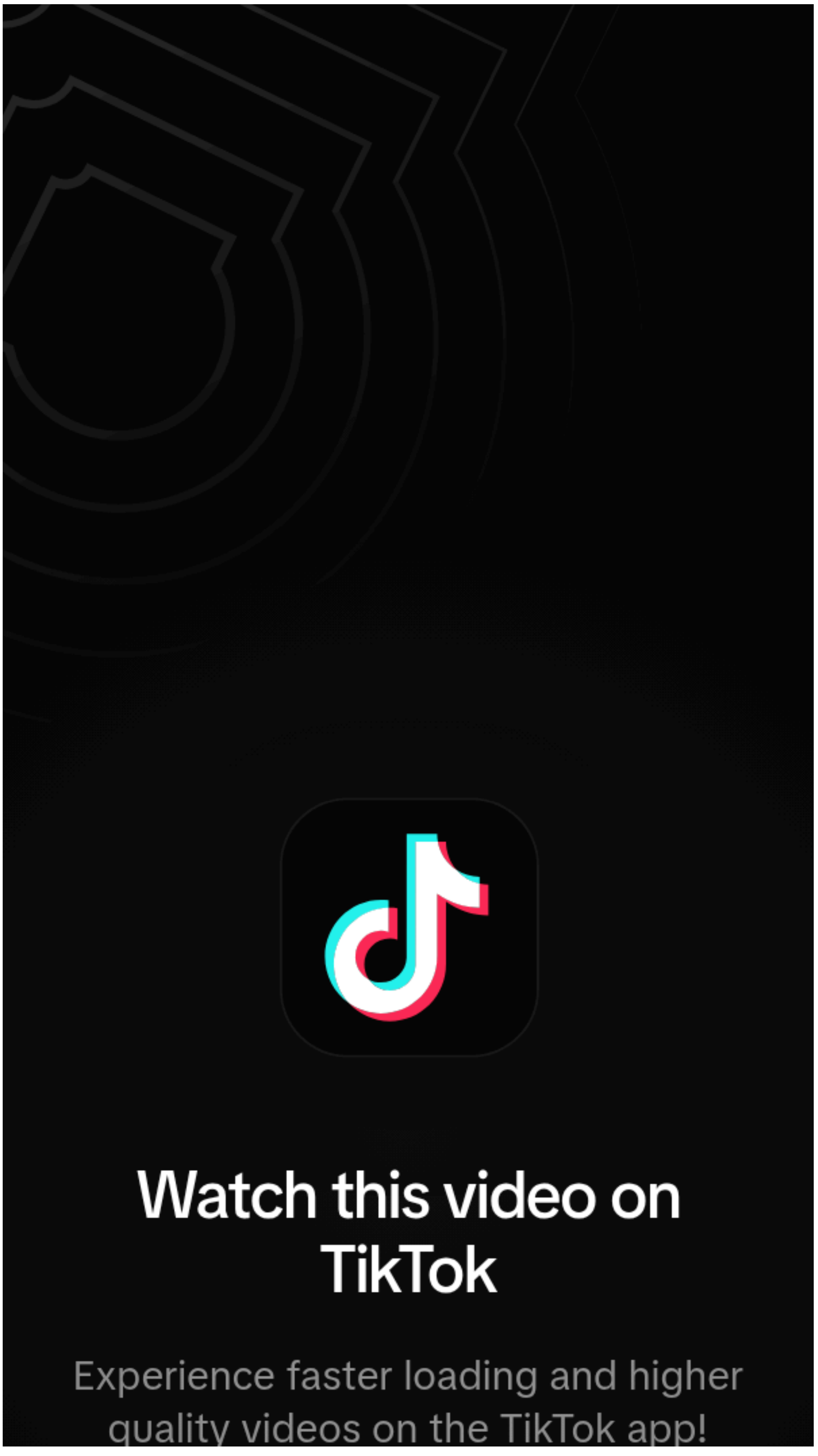
free cybersecurity hacking turtorials download - ebooks and videos scan the QR code to get the videos and ebooks on Terabox







How to Investigate a Username & Email Address With OSINT (Find Anyone Online) - LinuxGuy Cyber Security



https://seculearn-academy.base44.app

Just sharing that I’m exploring ethical hacking through my site. All content is legit, tested on my own setups, and fully legal. No targeting real networks, I swear. If you’re into cybersecurity, check it out!

SecuLearn

academy



✅Self-built cybersecurity academy

✅Super fast AI assistant

✅Complete video tutorials inside

✅Hands-on step-by-step learning

✅100% Free, no hidden charges

✅For cybersecurity beginners

一、信息收集（Information Gathering）

Nmap Nmap

作用：网络与端口扫描工具，可探测主机存活、开放端口、服务版本及操作系统类型，是信息收集阶段最基础的工具。
用法：通过指定目标IP/网段及扫描参数执行扫描。

```
nmap -sV -sC -p- 192.168.1.10
```

Masscan

Masscan 作用：高速端口扫描器，可在短时间内扫描大范围IP段，常用于大规模资产测绘的初筛。用法：设置扫描速率与端口范围后对网段进行快速扫描。

```
masscan 192.168.1.0/24 -p1-65535 --rate=1000
```

theHarvester

theHarvester 作用：通过搜索引擎、PGP密钥服务器等公开渠道收集目标域名相关的邮箱、子域名、主机名等信息（OSINT）。
用法：指定目标域名和数据来源进行信息聚合。

```
theHarvester -d example.com -b google,bing
```

Recon-ng Recon-ng

作用：模块化的Web信息收集框架，界面类似Metasploit，集成了大量OSINT收集模块。用法：在交互式控制台中加载模块并设置目标参数后运行。

```
recon-ng
> marketplace install all >
workspaces create demo
```

Maltego

Maltego 作用：图形化情报关联分析工具，可将域名、邮箱、人员、公司等实体可视化关联，辅助绘制攻击面图谱。用法：创建Graph后输入种子实体（如域名），运行Transform获取关联数据。

OWASP Amass

Amass 作用：子域名枚举与网络资产测绘工具，整合被动数据源与主动DNS解析，用于发现目标的完整攻击面。用法：对指定域名执行枚举，输出子域名列表。

```
amass enum -d example.com
```

Sublist3r

Sublist3r 作用：轻量级子域名枚举脚本，通过搜索引擎和公开数据源快速列出目标的子域名。用法：指定域名执行枚举。

```
sublist3r -d example.com
```

dnsenum

dnsenum 作用：DNS信息枚举工具，可获取目标的NS、MX记录并尝试域传送（Zone Transfer）及子域名爆破。 用法：指定域名执行DNS信息收集。

```
dnsenum example.com
```

whois WHOIS

作用：查询域名或IP的注册信息，包括注册人、注册商、注册/到期时间等。用法：直接查询域名。

```
whois example.com
```

Fierce Fierce

作用：DNS侦察工具，用于定位目标企业内外部网络空间中的IP地址与主机名。

用法：指定域名进行DNS扫描。

```
fierce --domain example.com
```

DMitry (Deepmagic Information Gathering Tool) DMitry

作用：综合信息收集工具，一条命令即可完成whois查询、子域名搜索、端口扫描等多项工作。

用法：使用参数组合执行多种信息收集功能。

```
dmitry -winsep example.com
```

SpiderFoot SpiderFoot

作用：自动化OSINT框架，可自动调用上百个数据源对目标进行被动/主动信息收集并生成关联报告。

用法：通过Web界面或命令行指定目标并选择扫描模块。

```
spiderfoot -s example.com -u all
```

Netdiscover Netdiscover

作用：基于ARP的局域网主机发现工具，可在无DHCP信息时快速发现同网段存活主机。

用法：指定网段进行被动或主动ARP扫描。

```
netdiscover -r 192.168.1.0/24
```

二、漏洞扫描（Vulnerability Scanning）

Nikto Nikto

作用：Web服务器漏洞扫描器，可检测过时组件、危险文件、常见配置错误等数千种已知问题。

用法：指定目标URL执行扫描。

```
nikto -h http://192.168.1.10
```

OpenVAS OpenVAS / Greenbone

作用：开源漏洞管理与扫描平台，拥有庞大的漏洞特征库，可对主机、服务进行全面漏洞评估。

用法：通过Web控制台创建扫描任务并指定目标。

Wapiti Wapiti

作用：Web应用漏洞扫描工具，通过爬取页面并注入测试向量检测SQL注入、XSS等常见漏洞。

用法：指定目标URL进行自动化扫描。

```
wapiti -u http://192.168.1.10/
```

WPScan WPScan

作用：专用于WordPress的安全扫描器，可枚举插件/主题版本、用户名并匹配已知漏洞库。

用法：指定目标WordPress站点地址进行扫描。

```
wpscan --url http://example.com --enumerate u,p,t
```

xray xray

作用：国产被动/主动式漏洞扫描工具，支持代理抓包被动扫描和主动爬虫扫描两种模式。

用法：以代理模式监听流量或对URL进行主动扫描。

```
xray webscan --basic-crawler http://192.168.1.10
```

三、Web应用测试（Web Application Analysis）

Burp Suite Burp Suite

作用：Web安全测试平台，集代理拦截、重放（Repeater）、爆破（Intruder）、扫描于一体，是Web渗透测试的核心工具。

用法：配置浏览器代理指向Burp监听端口，拦截并分析/修改HTTP请求。

ZAP (Zed Attack Proxy) OWASP ZAP

作用：开源Web应用安全扫描器，功能与Burp类似，支持自动化主动扫描和手动代理探索。

用法：通过GUI或命令行对目标站点执行主动扫描。

```
zap-cli quick-scan http://192.168.1.10
```

sqlmap sqlmap

作用：自动化SQL注入检测与利用工具，可识别数据库类型、枚举库表、读取数据，甚至获取交互式shell。

用法：指定存在可疑参数的URL，由工具自动检测并利用注入点。

```
sqlmap -u "http://192.168.1.10/item.php?id=1" --dbs
```

Dirb, Gobuster, ffuf Dirb / Gobuster / ffuf

作用：目录/文件爆破工具，使用字典对Web服务器上隐藏的目录、文件、子域名等进行枚举发现。

用法：指定目标URL与字典文件进行扫描。

```
gobuster dir -u http://192.168.1.10 -w /usr/share/wordlists/dirb/common.txt
```

Wfuzz Wfuzz

作用：通用Web模糊测试工具，可对URL的任意位置（参数、Header、路径等）进行字典爆破测试。

用法：使用FUZZ关键字标记测试位置并指定字典。

```
wfuzz -c -z file,/usr/share/wordlists/common.txt http://192.168.1.10/FUZZ
```

WhatWeb WhatWeb

作用：网站指纹识别工具，可识别CMS类型、Web服务器、编程语言及使用的框架/插件版本。

用法：指定目标URL进行指纹探测。

```
whatweb http://192.168.1.10
```

XSStrike XSStrike

作用：专注于XSS漏洞检测的高级扫描工具，具备上下文分析与payload自动生成能力。

用法：指定目标URL并带参数运行。

四、密码攻击（Password Attacks）

John the Ripper (JtR) John the Ripper

作用：经典密码哈希破解工具，支持数百种哈希格式的字典攻击、暴力破解和规则变换攻击。

用法：指定哈希文件及破解模式运行。

```
john --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt
```

Hashcat Hashcat

作用：基于GPU加速的高性能密码哈希破解工具，支持数百种哈希算法，速度远超CPU破解工具。

用法：指定哈希类型、攻击模式及字典/掩码进行破解。

```
hashcat -m 0 -a 0 hashes.txt rockyou.txt
```

THC-Hydra Hydra

作用：网络服务密码爆破工具，支持SSH、FTP、HTTP表单、RDP等数十种协议的在线暴力破解。

用法：指定目标服务、用户名/字典及密码字典进行爆破。

```
hydra -l admin -P rockyou.txt ssh://192.168.1.10
```

Medusa Medusa

作用：并行化的网络登录暴力破解工具，功能与Hydra类似，支持多种协议模块化扩展。

用法：指定模块、目标、用户名和密码字典进行爆破。

```
medusa -h 192.168.1.10 -u admin -P rockyou.txt -M ssh
```

Crunch Crunch

作用：字典生成工具，可按指定字符集、长度规则批量生成密码字典，供其他破解工具使用。

用法：指定最小/最大长度和字符集生成字典文件。

```
crunch 6 8 0123456789 -o dict.txt
```

CeWL CeWL

作用：基于网页内容生成自定义密码字典的工具，适合针对特定目标（公司、人物）定制字典。

用法：指定URL及抓取深度生成词表。

```
cewl http://example.com -d 2 -w wordlist.txt
```

五、无线攻击（Wireless Attacks）

Aircrack-ng Suite Aircrack-ng 套件

作用：无线安全评估工具集，包含airmon-ng（开启监听模式）、airodump-ng（抓包/扫描）、aireplay-ng（注入/解除认证）、aircrack-ng（密钥破解）等。

用法：先开启网卡监听模式，再抓取握手包，最后用字典破解。

```
airmon-ng start wlan0
airodump-ng wlan0mon
aircrack-ng -w rockyou.txt capture.cap
```

Wifite Wifite

作用：无线攻击自动化工具，整合Aircrack-ng等工具链，可自动化完成扫描、抓包、破解全流程。

用法：运行后按提示选择目标网络即可自动执行攻击链。

```
wifite
```

Reaver, Bully Reaver / Bully

作用：针对WPS（Wi-Fi Protected Setup）功能的PIN码暴力破解工具，可借助WPS漏洞获取WPA/WPA2密钥。

用法：指定网卡和目标BSSID进行WPS PIN爆破。

```
reaver -i wlan0mon -b -vv
```

Kismet Kismet

作用：无线网络探测与入侵检测工具，可被动嗅探周边无线网络、设备并记录数据包用于分析。

用法：启动后自动扫描并记录附近无线网络信息。

Fern Wifi Cracker Fern Wifi Cracker

作用：图形化无线网络安全审计工具，封装了WEP/WPA破解流程，适合初学者使用图形界面操作。

六、嗅探与欺骗（Sniffing & Spoofing）

Wireshark Wireshark

作用：图形化网络协议分析工具，可捕获并深入解析各层网络数据包，是流量分析的标准工具。

用法：选择网卡开始抓包，使用过滤表达式定位感兴趣的流量。

```
wireshark ■■■■■ http.request
```

tcpdump tcpdump

作用：命令行网络抓包工具，轻量灵活，常用于服务器环境下快速捕获和过滤数据包。

用法：指定网卡及过滤条件捕获流量。

```
tcpdump -i eth0 -w capture.pcap
```

Ettercap Ettercap

作用：中间人攻击工具，支持ARP欺骗、DNS欺骗及流量嗅探/篡改，常用于局域网安全测试。

用法：通过图形或命令行模式指定目标发起ARP欺骗。

```
ettercap -T -M arp:remote /192.168.1.1// /192.168.1.10//
```

Bettercap Bettercap

作用：新一代中间人攻击与网络侦察框架，功能涵盖ARP/DNS欺骗、HTTP/HTTPS流量操控、WiFi/BLE攻击等。

用法：进入交互模式后加载相应模块并设置参数。

```
bettercap -iface eth0
```

Responder Responder

作用：针对Windows网络中LLMNR/NBT-NS/mDNS协议的欺骗工具，可捕获并中继NTLM哈希。

用法：监听指定网卡等待局域网内的认证请求。

```
responder -I eth0
```

BeEF (Browser Exploitation Framework) BeEF

作用：浏览器漏洞利用框架，通过诱导目标浏览器加载hook.js脚本来控制浏览器、收集信息或联动Metasploit。

用法：启动BeEF服务后将hook脚本植入可控页面，等待目标上线。

七、漏洞利用框架（Exploitation Tools）

Metasploit (msfconsole) Metasploit Framework

作用：最知名的渗透测试框架，集成海量漏洞利用模块（exploit）、攻击载荷（payload）及辅助模块，可完成从扫描到获取shell的全流程。

用法：进入控制台搜索并加载漏洞模块，设置目标参数后执行。

```
msfconsole
> search type:exploit platform:windows
> use exploit/...
> set RHOSTS 192.168.1.10
> run
```

Armitage Armitage

作用：Metasploit的图形化前端，以可视化方式展示目标主机并管理攻击会话，降低上手门槛。

Social-Engineer Toolkit (SET) SET

作用：社会工程学攻击工具包，集成钓鱼邮件、凭据窃取页面、HTA攻击等多种社工攻击手法模板。

用法：交互式菜单选择攻击类型（如网站克隆钓鱼）并配置参数。

```
setoolkit
```

Empire, Starkiller PowerShell Empire / Starkiller

作用：后渗透与C2（命令控制）框架，专注于PowerShell/Python Agent的管理，Starkiller为其图形化界面。

八、提权与后渗透（Privilege Escalation & Post-Exploitation）

PowerSploit PowerSploit

作用：PowerShell攻击脚本合集，涵盖信息收集、权限维持、提权检测（PrivEsc）、规避检测等模块。

用法：在目标PowerShell环境中导入脚本模块并调用相应函数。

Nishang Nishang

作用：另一套PowerShell攻击与后渗透脚本框架，提供反弹Shell、键盘记录、权限维持等脚本。

Mimikatz Mimikatz

作用：Windows凭据提取工具，可从内存（LSASS）中提取明文密码、哈希、票据等认证信息，常用于内网横向移动。

用法：在目标主机（获得权限后）运行并执行凭据导出命令。

```
mimikatz.exe
privilege::debug
sekurlsa::logonpasswords
```

LinPEAS, WinPEAS LinPEAS / WinPEAS

作用：自动化本地提权信息收集脚本，分别针对Linux/Windows系统扫描可能的提权路径（弱权限文件、服务配置错误等）。

用法：在目标系统上传并执行脚本，输出彩色高亮的提权线索。

```
./linpeas.sh
```

Netcat (nc), Socat Netcat / Socat

作用：多功能网络工具，常被称为“瑞士军刀”，可用于端口监听、反弹/正向Shell、文件传输及端口转发等。

用法：监听本地端口等待连接，或主动连接目标端口。

```
nc -lvnp 4444
```

Chisel, Proxychains Chisel / Proxychains

作用：内网穿透与流量代理工具，Chisel基于HTTP建立隧道，Proxychains可强制其他程序的流量走指定代理，常用于横向移动访问内网资源。

Cobalt Strike Cobalt Strike

作用：商业级红队协同作战平台，提供Beacon载荷、团队协作、权限维持、流量伪装等高级C2能力，常用于模拟高级威胁场景演练。

九、取证分析与逆向工程（Forensics & Reverse Engineering）

Autopsy Autopsy / Sleuth Kit

作用：数字取证分析平台，可对磁盘镜像进行文件恢复、时间线分析、关键字搜索等取证工作。

Volatility Volatility

作用：内存取证分析框架，可从内存镜像中提取进程列表、网络连接、注入代码等痕迹，常用于应急响应。
用法：指定内存镜像文件及画像（profile）执行相应插件。

```
volatility -f memory.dmp --profile=Win10x64 pslist
```

Binwalk Binwalk

作用：固件/二进制文件分析工具，可识别并提取嵌入在文件中的文件系统、压缩包等隐藏数据，常用于IoT设备固件分析。
用法：指定固件文件进行特征扫描和自动提取。

```
binwalk -e firmware.bin
```

Ghidra, radare2 Ghidra / radare2

作用：开源逆向工程框架，支持反汇编、反编译，用于分析二进制程序的内部逻辑与漏洞挖掘。

Apktool, Jadx Apktool / Jadx

作用：Android APK反编译工具，可将APK还原为可读的Smali代码或接近原始的Java源码，便于安全审计。
用法：指定APK文件进行反编译。

```
apktool d app.apk
```

This is a Free step to step guide book

About Me

terabox

Author:Terry.liu